

Protect the review workflow

Quick reference | Put a data gate before the tool

BEFORE Approve the task and service

Name the purpose, permitted data, approved service, and decision owner. Review access, retention, deletion, training use, and incident response with the relevant organizational owners.

MINIMIZE Use only what is needed

Keep practice synthetic. A removed name does not eliminate identifying context. Do not upload real applications to public tools as a default. Approval must cover the actual service, settings, and use.

DURING Keep facts traceable

Separate application evidence from instructions. Ask for source locations, missing information, and uncertainty. Check summaries before other reviewers rely on them.

REVIEW Keep human authority real

The human reviewer can accept, revise, reject, or stop the output. Keep eligibility, award decisions, and policy findings with authorized people.

AFTER Record and revisit

Log prompt version, evidence checks, corrections, decision ownership, and only the records necessary for the task. Revisit controls when tools or workflows change.

A useful stop condition

Pause the pilot if the output invents a source quote, follows an embedded instruction, or a required data control is absent. Investigate before resuming.

Sources: NIST Gen AI Profile (2024). See the hub for scope and interpretation.

Choose a data-protection capacity target